

Lab :Création d'un certificat x509 autosigné pour un serveur web sous GNU/Linux

Introduction :

Dans le contexte de la sécurité des communications sur Internet, les certificats, les clés privées et les clés publiques sont des concepts fondamentaux. Comprendre ces concepts est essentiel pour assurer la confidentialité et l'authenticité des données échangées entre les parties.

Certificat SSL/TLS : Un certificat SSL/TLS (Secure Sockets Layer/Transport Layer Security) est un fichier électronique qui lie de manière cryptographique les informations d'identification d'une entité (par exemple, un site web, un serveur de messagerie) à une clé publique. Il est utilisé pour établir une connexion sécurisée entre un client et un serveur via le protocole HTTPS. Les certificats sont délivrés par des autorités de certification (CA) de confiance, qui vérifient l'identité du demandeur avant de lui attribuer un certificat.

X.509 est un format de certificat numérique largement utilisé dans les infrastructures à clé publique (PKI) pour authentifier l'identité des parties impliquées dans une communication sécurisée sur un réseau informatique, tels que les sites web, les serveurs de messagerie, les VPN, etc.

Clé Privée : Une clé privée est une donnée secrète utilisée dans les systèmes de cryptographie asymétrique. Elle est associée à une clé publique dans une paire de clés. La clé privée est conservée en secret par son propriétaire et est utilisée pour signer numériquement des données ou déchiffrer des messages chiffrés avec la clé publique correspondante. En matière de certificats SSL/TLS, la clé privée est utilisée pour signer les données du certificat, prouvant ainsi son authenticité.

Clé Publique : Une clé publique est une partie d'une paire de clés asymétriques associée à une clé privée. Contrairement à la clé privée, la clé publique est partagée publiquement et peut être utilisée par toute personne pour chiffrer des données ou vérifier la signature numérique générée avec la clé privée correspondante.

Dans le contexte des certificats SSL/TLS, la clé publique est incluse dans le certificat et est utilisée par les clients pour chiffrer les données sensibles envoyées au serveur.

PKI/IGC/ICP (Infrastructure de Gestion de Clé) :Une Infrastructure de Gestion de Clé (PKI en anglais pour *Public Key Infrastructure*, IGC en français) désigne un système permettant de gérer les clés cryptographiques et les certificats numériques. Cette infrastructure est utilisée pour sécuriser les communications électroniques en garantissant :

- **L'authenticité** des entités impliquées dans les échanges grâce aux certificats numériques émis par une autorité de certification (CA).
- **L'intégrité** des données échangées, en s'assurant qu'elles n'ont pas été altérées pendant la transmission.

- **La confidentialité**, qui est obtenue indirectement grâce au chiffrement basé sur les clés publiques et privées associées aux certificats.

Le protocole OCSP

Lorsqu'un navigateur reçoit un certificat d'un serveur web, il doit vérifier sa validité en s'assurant qu'il n'a pas été révoqué. Cette vérification repose sur :

- **OCSP (Online Certificate Status Protocol)** : Le navigateur envoie une requête au serveur OCSP de l'autorité de certification pour vérifier l'état du certificat. Le serveur répond en indiquant si le certificat est valide, révoqué ou inconnu.
- **OCSP Stapling** : Une optimisation où le serveur web effectue lui-même la requête OCSP et inclut la réponse signée dans le processus de handshake TLS, réduisant ainsi les délais de vérification pour le client.
- **CRL (Certificate Revocation List)** : Une méthode plus ancienne où le navigateur télécharge une liste des certificats révoqués depuis la CA. Cette méthode est désormais rarement utilisée en raison de son inefficacité.

Ces mécanismes garantissent que les certificats utilisés pour établir des connexions sécurisées sont toujours valides et fiables.

OpenSSL, un outil open-source utilisé pour sécuriser les communications sur Internet.

En utilisant OpenSSL, les administrateurs système et les développeurs peuvent mettre en place des infrastructures sécurisées pour leurs applications et services en ligne.

Wiki : [PKI](#)

Objectif :

Le but de ce laboratoire est de générer un certificat x509 autosigné à l'aide d'OpenSSL et de le configurer pour être utilisé avec Apache sur une machine virtuelle Ubuntu. Cela permettra d'établir une connexion sécurisée entre les clients et le serveur Apache via le protocole HTTPS.

Prérequis :

- Une machine virtuelle Ubuntu
- Connexion internet pour télécharger les paquets.

Instructions :

Ouvrez un terminal shell :

1. Installation d'openssl et d'apache2 :

```
sudo apt update  
sudo apt install openssl apache2
```

2. **Génération d'une clé privée** : Utilisez la commande suivante pour générer une clé privée RSA de 2048 bits :

```
openssl genrsa -out server.key 2048
```

3. **Génération d'une demande de signature de certificat (CSR)** : Utilisez la clé privée pour créer un CSR en spécifiant les détails du certificat. OpenSSL vous posera plusieurs questions pour remplir les champs requis. Voici un exemple de saisie des informations :

```
openssl req -new -key server.key -out server.csr
```

Vous devrez répondre à des questions telles que le pays, la province, la ville, le nom de l'organisation, etc. Assurez-vous de fournir des informations précises, en particulier pour le champ "Common Name" qui doit correspondre exactement au nom de domaine du serveur.

Voici un exemple de saisie des informations :

```
Country Name (2 letter code) [AU]:FR
State or Province Name (full name) [Some-State]:Ile-de-France
Locality Name (eg, city) []:Paris
Organization Name (eg, company) [Internet Widgits Pty
Ltd]:Example Company
Organizational Unit Name (eg, section) []:
Common Name (e.g. server FQDN or YOUR name) []:www.example.com
Email Address []:admin@example.com
```

4. **Génération d'un certificat autosigné** : Utilisez le CSR pour générer un certificat autosigné valable, par exemple, pendant 365 jours :

```
openssl x509 -req -days 365 -in server.csr -signkey server.key -out
server.crt
```

5. **Configuration d'Apache** : Copiez les fichiers de clé privée et de certificat dans les répertoires appropriés d'Apache :

```
sudo cp server.crt /etc/ssl/certs/
sudo cp server.key /etc/ssl/private/
```

6. **Configuration du virtual host Apache** : Éditez le fichier de configuration Apache pour ajouter un virtual host SSL :

```
sudo nano /etc/apache2/sites-available/default-
ssl.conf
```

Ajoutez ou modifiez les lignes suivantes pour pointer vers les fichiers de clé et de certificat :

```
SSLCertificateFile /etc/ssl/certs/server.crt
SSLCertificateKeyFile /etc/ssl/private/server.key
```

7. **Activation du module SSL et redémarrage d'Apache** : Activez le module SSL et redémarrez Apache pour appliquer les modifications :

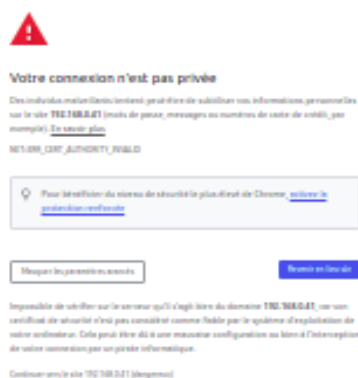
```
sudo a2enmod ssl
cd /etc/apache2/sites-enabled
sudo ln -s ../sites-available/default-ssl.conf .
sudo /etc/init.d/apache2 restart
```

8. **Test de connexion au serveur web sécurisé** : Après avoir configuré Apache avec le certificat autosigné, vous pouvez ouvrir un navigateur web et accéder à votre site via HTTPS (par exemple, <https://localhost>).

Le navigateur affichera probablement un avertissement concernant le certificat non valide ou non vérifié. Cela se produit parce que le certificat est autosigné et n'est pas émis par une autorité de certification reconnue par le navigateur. Pour contourner cet avertissement, l'utilisateur doit accepter le certificat ou ajouter une exception dans les paramètres du navigateur.

Bien que le certificat soit sécurisé, le navigateur alerte l'utilisateur car il ne peut pas garantir l'identité du serveur.

Alert du navigateur pour indiquer que le certificat est invalide (auto signé)



--chrome firefox-->

